

Controls Assessment Priority

Botium Toys | My Prioritization of Outstanding Controls

The controls checklist identified which security controls Botium Toys currently has in place. This document ranks the controls that are **not** yet implemented by priority, based on the risk they address, the control type, and the severity described in the risk assessment report (overall risk score: 8/10, driven primarily by access management and data protection gaps rather than physical security).

Administrative Controls

Control	Type	Why It Matters	Priority
Least Privilege	Preventative	All employees currently have access to cardholder data and PII/SPII with no role-based restriction — the single largest driver of the audit's high risk score.	High
Separation of Duties	Preventative	Without this, one person could both process and approve sensitive transactions, creating fraud risk with no compensating check.	High
Disaster Recovery Plan	Corrective	No backups exist. A single incident (ransomware, hardware failure) could mean permanent data loss with no recovery path.	High
Password Policies	Preventative	Existing policy doesn't meet modern minimum complexity standards, making accounts easier to compromise via brute force.	Medium

Technical Controls

Control	Type	Why It Matters	Priority
Encryption	Deterrent	Credit card data is processed and stored locally without encryption — a direct PCI DSS violation with real regulatory/fine exposure.	High
Backups	Corrective	Tied directly to the missing disaster recovery plan; no path to restore data after loss or attack.	High
Intrusion Detection System (IDS)	Detective	No way to detect anomalous network activity or an active breach in progress.	High
Password Management System	Corrective	Manual password resets slow the IT team down and make it harder to enforce a stronger policy consistently.	Medium
Manual Monitoring for Legacy Systems	Prevent./Correct.	Legacy systems are monitored, but with no defined schedule — lower urgency since some oversight already exists.	Medium

Physical Controls

Locks, CCTV, fire detection/prevention, and the firewall and antivirus software are already in place and functioning, per the risk assessment report. No action needed here — physical security is the strongest part of Botium Toys' current

posture.

My Reasoning

I prioritized controls that directly address the two biggest risk drivers called out in the audit: unrestricted access to sensitive data, and the absence of encryption or backups for that data. These carry both security risk (breach, fraud, data loss) and regulatory risk (PCI DSS and GDPR non-compliance, which can mean fines). Controls tied to operational efficiency rather than direct risk exposure (centralized password management, a formal legacy system schedule) I ranked as Medium — still important, but less urgent than closing the access and data-protection gaps.